

# Automatizando pruebas de seguridad a modelos IA

promptfoo

# 2025 / 2026 Un crecimiento desmedido.

En que momento la IA empezó a ser un elemento cotidiano en las empresas?

2025

## El primer modelo

Por cada modelo desplegado en el 2025



2026

## Múltiples modelos

A 2026 se tiene un promedio de 15 a 18 modelos de mas implementados.

**PREGUNTA CLAVE · ¿Son modelos genéricos o a medida?**

**proporción de escala:** por cada modelo o agente de IA que las organizaciones tenían activo en sus flujos de trabajo en marzo de 2025, hoy en 2026 hay 15 operando en paralelo.

# Cinco áreas que adoptan IA en sus procesos .

Cada área laboral adopta modelos de IA según su necesidad.

### 01 Manufactura

Mantenimiento predictivo.
Control de calidad automatizado.
Diseño generativo.

### 02 Banca

Detección y prevención de fraudes.
Evaluación de riesgo crediticio.
Asistentes financieros virtuales.

### 03 Software

Generación y completado de código.
Automatización de pruebas (QA Testing).
Documentación técnica automática.

### 04 Media y comunicaciones

Motores de recomendación hiperpersonalizados.
Generación y edición de contenido multimedia.
Optimización y mantenimiento de redes.

### 05 Retail

Gestión predictiva de inventarios.
Precios dinámicos (Dynamic Pricing).
Búsqueda visual e inteligente.

FUENTE: https://www.microsoft.com/en-us/worklab/work-trend-index/agents-human-agency-and-the-opportunity-for-every-organization

# Estamos preparados para tal crecimiento ?

Tres conceptos relacionados, con distintos niveles de especificidad.

01

## USO REGULAR

88% de las organizaciones informan un uso regular de la IA en al menos una función empresarial en 2025, frente al 78% en 2024 y al 55% in 2023.

02

## USO REGULADO

41% de los trabajadores en EE. UU. utilizaron IA generativa para el trabajo en noviembre de 2025; el 50% la utilizó para fines no laborales.

03

## TRAE TU PROPIA IA

78% de los usuarios de IA llevan sus propias herramientas de IA al trabajo, cifra que aumenta al 85% entre los trabajadores de la Generación Z.

04

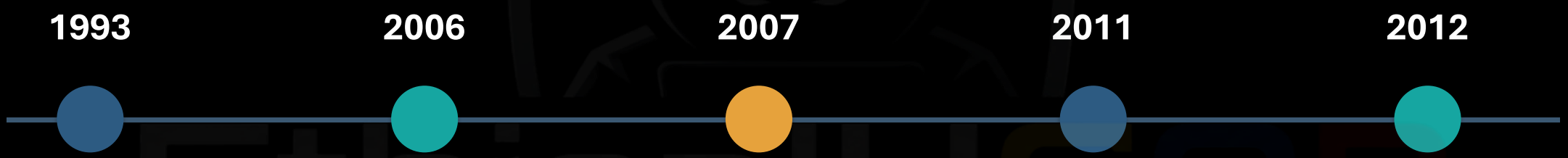
## SIN POLITICAS

44% de los trabajadores en EE. UU. afirman que su empleador no tiene una política clara sobre IA, o no están seguros de si existe alguna.

**FUENTE: https://www.brilo.ai/es/recursos/estadisticas-de-uso-de-ia**

# Una revolución tecnológica que se repite .

La superficie de ataque evoluciona a medida que cambian las plataformas y las capacidades.




**Web**

RCE · SQLi · XSS · SSRF

**Cloud**

Escape del entorno cloud, exfiltración de metadata, robo de subdominios

**Smartphones**

Malware, protocolos de emparejamiento y suplantación

**Asistentes de voz**

Speaker verification spoofing y LightCommands

**Deep Learning**

Data poisoning y model extraction

# Red Teaming tradicional vs. Red Teaming de IA

El objetivo sigue siendo encontrar debilidades; cambian los activos y los métodos de prueba.

| CATEGORÍA | TRADICIONAL | IA |
|---|---|---|
| **Objetivo** | Redes, servidores, aplicaciones y seguridad física | Modelos, pipelines de datos, fuentes de entrenamiento y lógica de prompts |
| **Técnicas** | Exploits, malware, phishing y escalamiento de privilegios | Jailbreaking, prompt injection, extracción del modelo e inputs maliciosos |
| **Predictibilidad** | Comportamiento relativamente predecible | Resultados menos predecibles |
| **Ejemplo** | Acceder a una base de datos y extraer información privada | Inducir al modelo a revelar información privada mediante un prompt malicioso |

# Cinco áreas que conviene poner a prueba

Cada superficie describe una forma distinta de provocar un comportamiento no previsto.

### 01 Prompt Injection

Manipular instrucciones para que el modelo ignore reglas, revele información o ejecute acciones no autorizadas.

LLM01:2026

### 03 Abuso de funcionalidades

Abusar de herramientas propias del modelo para extraer, modificar, crear o eliminar información del entorno de ejecución.

LLM03:2026

### 05 Data Poisoning

Contaminar datos de entrenamiento, ajuste o conocimiento para influir deliberadamente en el sistema.

LLM05:2026

### 02 Extracción del modelo

Aproximar un modelo propietario mediante consultas y observación de sus respuestas.

LLM02:2026

### 04 Cadena de suministro

Afectar modelos re-entrenados para que su parametrización afecte el producto final.

LLM04:2026

**MARCOS DE REFERENCIA** OWASP · MITRE ATLAS · NIST AI RMF

# ¿Qué es promptfoo?

Una herramienta de código abierto para evaluar y probar la seguridad de aplicaciones basadas en LLM.

## promptfoo

OPEN SOURCE

No es un modelo de IA. Es una herramienta para poner a prueba los modelos, prompts y aplicaciones que construyes.

**CLI + biblioteca de evaluación**

**Documentación Oficial:** https://www.promptfoo.dev/docs/intro/

### A — Evaluación

Ejecuta casos de prueba para medir utilidad y cumplimiento de criterios; permite comparar modelos o versiones de prompts.

### B — Red teaming

Prueba entradas adversariales y busca debilidades como saltarse instrucciones o revelar información.

*La presentación original indica más de 50 tipos de vulnerabilidades.*

# Recorrido por la aplicación

Tres momentos para entender cómo se usa promptfoo en la práctica.

SESIÓN EN VIVO

## DEMO

**Evaluación y Red Teaming**

**https://medium.com/@ethicalhcop/automatizando-pruebas-a-ia-con-promptfoo-bc651948477d**

01

### Recorrido por la app

Ubicar las áreas principales de la herramienta.

02

### Evaluación

Revisar cómo se ejecutan casos de prueba.

03

### Red Team

Explorar pruebas de seguridad frente a entradas adversariales.

# La realidad de la automatización

La seguridad de un sistema con IA requiere evaluar el comportamiento, no solo inspeccionar el código.

## Prueba manual

Cambiar palabras y comprobar “si suena bien”.

- Variar el prompt
- Observar la respuesta
- Volver a probar

VS

## Pruebas automatizadas

Evaluar de forma repetible frente a criterios definidos.

- Ejecutar un conjunto de casos
- Comparar resultados
- Detectar regresiones de comportamiento

**OBJETIVO: ESCALAR LA EVALUACIÓN DEL COMPORTAMIENTO**

# Conclusiones y buenas prácticas

Convertir la evaluación de seguridad en una práctica repetible y controlada.

## CONCLUSIONES

01 **La prueba manual no escala.**

Cambiar palabras hasta que una respuesta “suene bien” no es suficiente.

02 **Automatizar las pruebas.**

Ayuda a detectar cuando el agente rompe reglas, insulta o filtra datos.

03 **Evalúa el comportamiento.**

Los proveedores optimizan para el público general, no para las reglas de tu negocio.

## BUENAS PRÁCTICAS

1 **Versiona los endpoints**

Evita endpoints dinámicos en producción: las actualizaciones silenciosas pueden cambiar el comportamiento.

2 **Restringe los argumentos**

Define esquemas JSON estrictos para las herramientas y sus argumentos.

3 **Protege en el receptor**

La seguridad debe aplicarse en el código receptor, no depender solo del prompt.

# Por Su Atención.
# Muchas Gracias !!!